

LAB 05

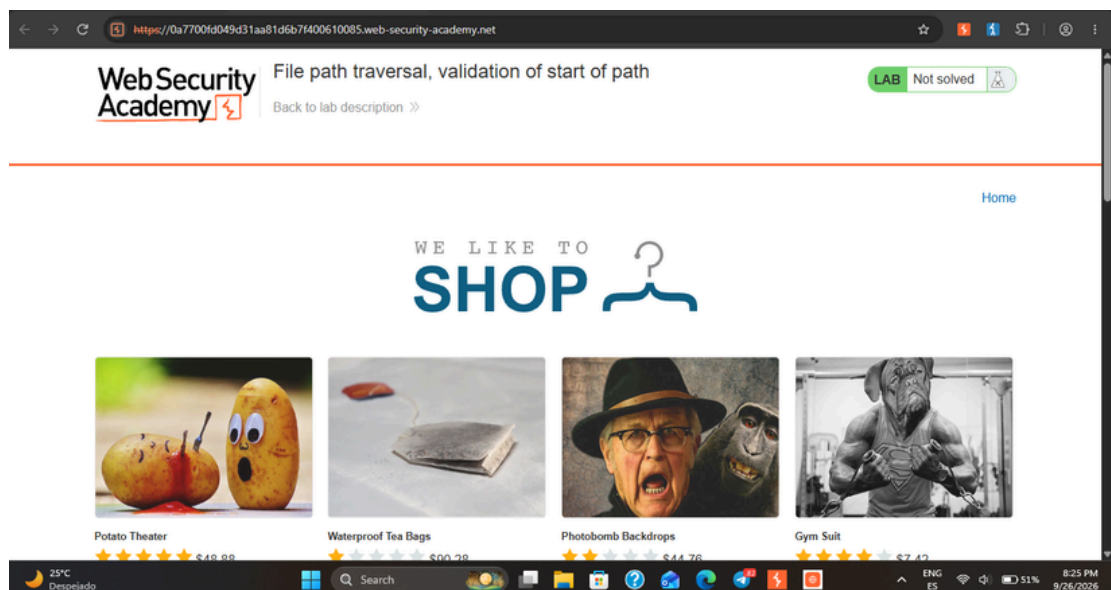
FILE PATH TRAVERSAL, VALIDATION OF START OF PATH

LUIS EMMANUEL ARONIA SILVA

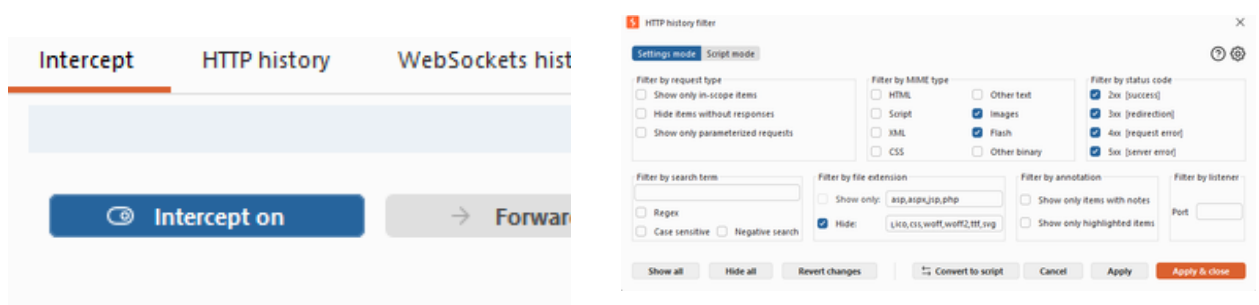
Universidad Politecnica de San Luis Potosi

26/09/2026

El primer paso para resolver este laboratorio es iniciar la aplicacion de Burp Suite, esto para abrir el navegador que esta contiene, el cual se encuentra bajo la pestaña de Proxy, seguido de la de Intercept, ahi encontraremos el boton de Open Browser, una vez en el navegador hay que ingresar con el link oficial del laboratorio y loguearse con la cuenta para empezar a resolver, teniendo hasta este punto la siguiente vista:



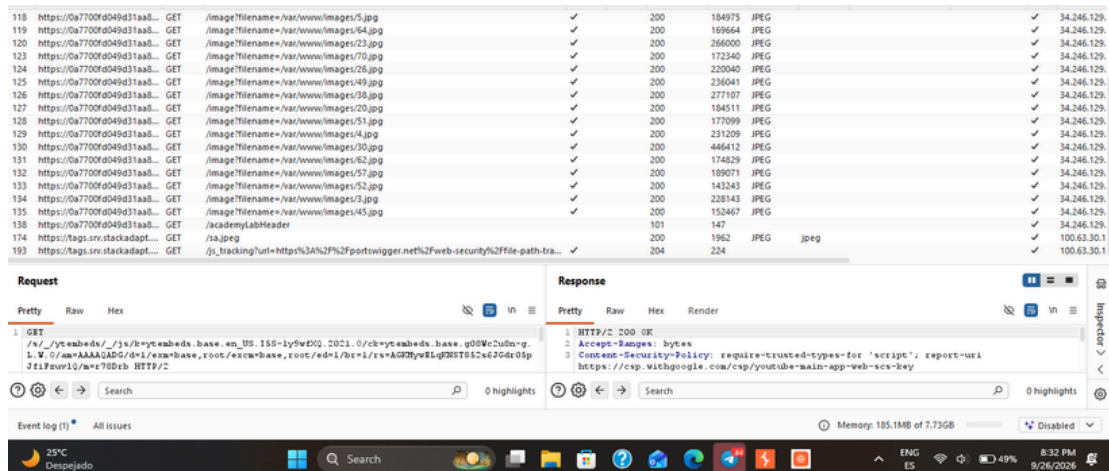
Una vez estemos aqui ahora hay que buscar capturar la peticion de alguna imagen a la que hagamos click, para esto primero hay que asegurarnos de que el boton de Intercept en la aplicacion Burp Suite este en On y que no haya algun filtro que impida que se muestren



LAB 05

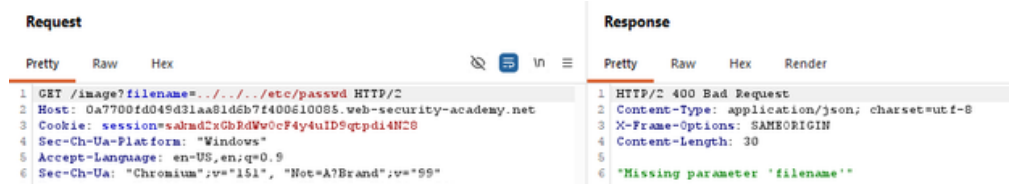
FILE PATH TRAVERSAL, VALIDATION OF START OF PATH

Ahora si que lo anterior esta listo dentro de las peticiones estamos buscando alguna que se vea de la siguiente manera: **GET /image?filename=/var/www/images/XX.jpg HTTP/1.1**

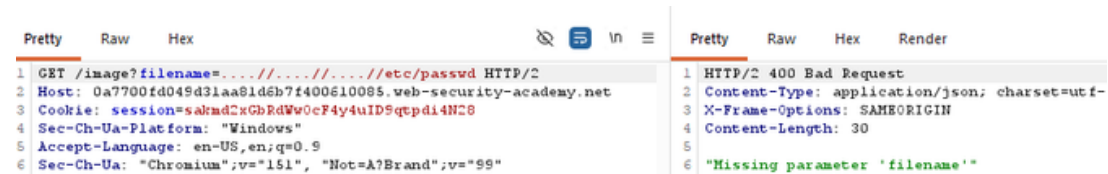


Ahi estan las peticiones, ahora hay que tomar una de ellas, dar click derecho y seleccionar la opcion Send to Repeater, donde podremos probar payloads como los anteriores

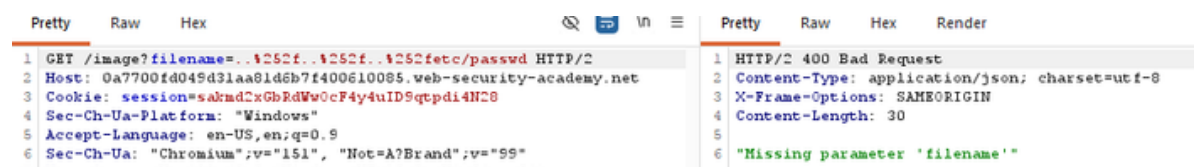
../../etc/passwd



....//....//....//etc/passwd



..%252f..%252f..%252fetc/passwd



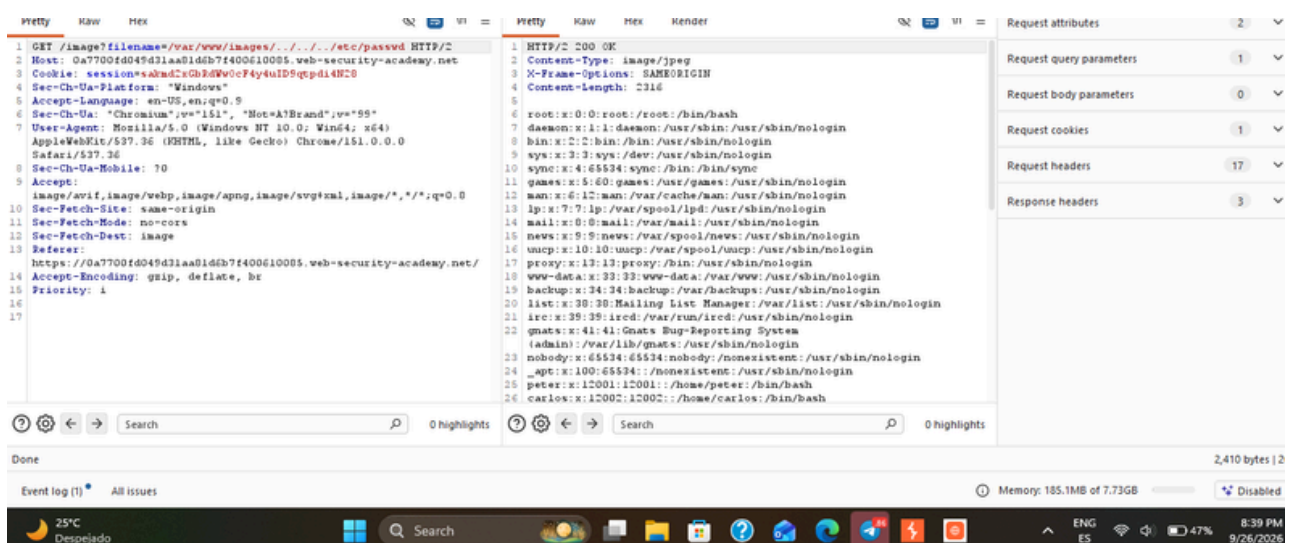
LAB 05

FILE PATH TRAVERSAL, VALIDATION OF START OF PATH

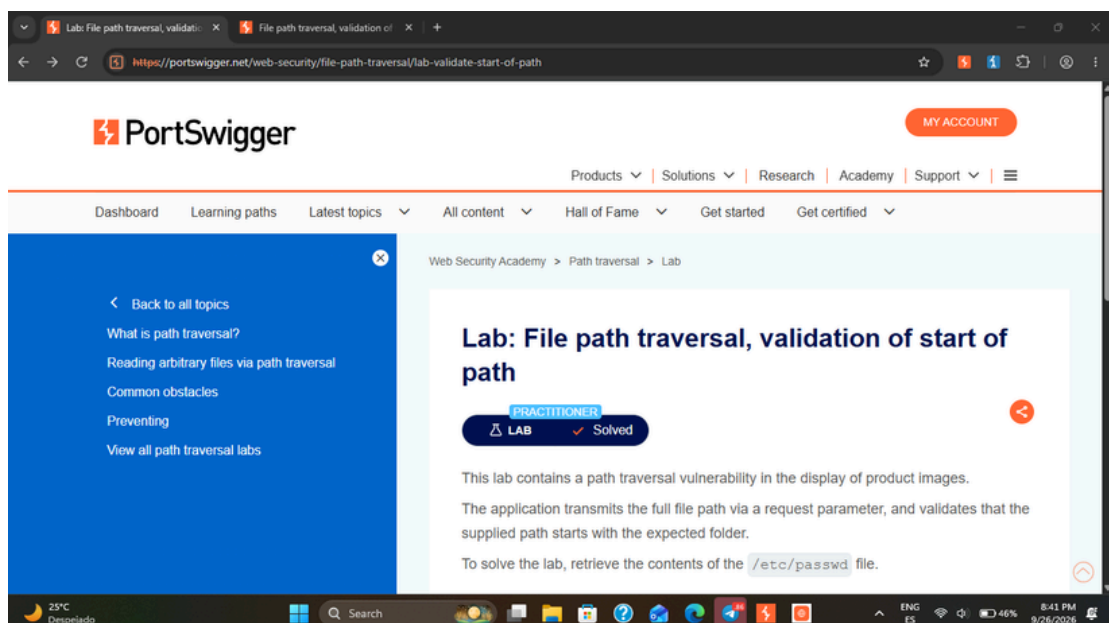
Pero como se puede observar ninguno de estos funciona, y es que la aplicación exige que el valor del parámetro comience con la carpeta esperada, que es **/var/www/images**. Por eso debemos respetar ese prefijo y luego salir con **../**

Entonces el correcto debe de ser el siguiente:

/var/www/images/../../etc/passwd



Ahora con este payload en el panel de Response se puede observar como se logro recuperar por completo el contenido de **/etc/passwd**



LAB 05

FILE PATH TRAVERSAL, VALIDATION OF START OF PATH

Explicacion Tecnica

La aplicación valida que el valor del parámetro filename empiece con la ruta esperada:

`/var/www/images/`

Si el valor no comienza con esa cadena, lo rechaza, al enviar:

`/var/www/images/../../etc/passwd`

- La validación se cumple (sí empieza con `/var/www/images`).
- Luego el servidor procesa los `../` y sube tres niveles:
- Sale de **`/images/`**
- Sale de **`/www/`**
- Sale de **`/var/`**
- Finalmente llega a la raíz y lee **`/etc/passwd`**